PLATFORMA YUMMY • DOKUMENTACJA SYSTEMU

Załącznik nr 2 do Umowy

Bezpieczeństwo i ochrona danych

Architektura zabezpieczeń, SSL/TLS, kontrola dostępu, RODO

Załącznik nr 2 do Umowy

Licencjobiorca: Yummy S.C. Marcin Krystosiak, Aleksandra Brzoza

Wersja dokumentu 1.1 • Październik 2026

DOKUMENT POUFNY – WYŁĄCZNIE DLA STRON UMOWY

Spis treści

1	Filozofia bezpieczeństwa – Security by Design
2	Szyfrowanie transmisji – certyfikaty SSL/TLS
3	Szyfrowanie danych w spoczynku i kopie zapasowe
4	Uwierzytelnianie i zarządzanie sesjami
5	Kontrola dostępu oparta na rolach (RBAC)
6	Izolacja danych na poziomie rekordów
7	Bezpieczeństwo logiki biznesowej i transakcji
8	Ochrona aplikacji internetowej
9	Bezpieczeństwo komunikacji w czasie rzeczywistym
10	Ochrona programu lojalnościowego przed nadużyciami
11	Integralność danych finansowych i fiskalnych
12	Ochrona danych osobowych – RODO
13	Infrastruktura, ciągłość działania i monitoring
14	Zarządzanie incydentami
15	Rekomendacje dla Licencjobiorcy
16	Weryfikacja zabezpieczeń

1. Security by Design

Bezpieczeństwo nie jest w platformie dodatkiem – jest fundamentem architektury, uwzględnianym na każdym etapie projektowania, programowania i utrzymania systemu.

Platforma przetwarza dane osobowe klientów, dane finansowe i fiskalne oraz dane operacyjne restauracji. Dlatego zastosowano model **obrony w głąb (defense in depth)**: wiele niezależnych warstw zabezpieczeń, z których każda samodzielnie ogranicza skutki ewentualnego naruszenia innej warstwy. Zasada **najmniejszych uprawnień (least privilege)** obowiązuje zarówno użytkowników, jak i komponenty systemu.

HTTPS	Rekordy	3 poziomy	100%
wymuszone szyfrowanie transmisji	izolacja danych na poziomie wierszy	uprawnień personelu	autoryzacja po stronie serwera

Warstwa	Zastosowane zabezpieczenia
Sieć i transmisja	HTTPS wymuszony, certyfikaty SSL/TLS, sieć brzegowa dostawcy infrastruktury z mechanizmami ochrony przed nadmiernym ruchem
Aplikacja	Nagłówki bezpieczeństwa, walidacja danych, ochrona przed przekierowaniami, ukrywanie sygnatur technologii
Tożsamość	Hasła hashowane, tokeny sesyjne z automatyczną rotacją, potwierdzanie adresu e-mail jednorazowym kodem
Autoryzacja	Model Administrator / Szef-Kierownik / Pracownik, weryfikacja uprawnień przy każdym żądaniu, odrębne konta urządzeń
Dane	Polityki dostępu na poziomie rekordów, operacje atomowe, szyfrowanie i kopie zapasowe w ramach usług dostawcy infrastruktury
Audyt	Rejestr zmian płatności, historia zamówień, blokady zamkniętych dni

2. Szyfrowanie transmisji – certyfikaty SSL/TLS

- Cała komunikacja pomiędzy przeglądarką, kioskiem, tabletami obsługi a platformą odbywa się wyłącznie szyfrowanym protokołem **HTTPS**.
- Stosowane są certyfikaty **SSL/TLS** wystawiane przez zaufane urzędy certyfikacji, **odnawiane automatycznie** przez dostawcę infrastruktury.
- Obsługiwane są nowoczesne wersje protokołu (TLS 1.2 i TLS 1.3) z silnymi zestawami szyfrów zapewniającymi utajnienie przekazywania (forward secrecy).
- Połączenia nieszyfrowane są automatycznie przekierowywane do wersji szyfrowanej.
- Komunikacja z warstwą danych oraz pomiędzy komponentami infrastruktury jest również szyfrowana.
- Kłódka w pasku przeglądarki potwierdza klientom autentyczność serwisu i buduje zaufanie do marki.

Zaufanie klienta

Ważny certyfikat SSL jest dziś warunkiem koniecznym nie tylko bezpieczeństwa, ale i widoczności w wyszukiwarkach oraz zaufania klientów. Platforma zapewnia go automatycznie dla wszystkich domen Licencjobiorcy.

3. Szyfrowanie w spoczynku i kopie zapasowe

- Dane przechowywane są w zarządzanej, chmurowej bazie danych klasy produkcyjnej; szyfrowanie danych w spoczynku zapewnia dostawca infrastruktury.
- Pliki (np. zdjęcia produktów) przechowywane są w zarządzanym magazynie obiektów z kontrolą dostępu.
- Kopie zapasowe bazy danych wykonywane są automatycznie w ramach mechanizmów dostawcy infrastruktury, codziennie, i przechowywane przez 7 dni.
- Kopie zapasowe umożliwiają odtworzenie danych po awarii w zakresie, w jakim pozwalają na to mechanizmy dostawcy.
- Każda zmiana struktury danych jest wersjonowana i wdrażana kontrolowanym procesem migracji.

3.1. Parametry kopii zapasowych

Parametr	Wartość
Częstotliwość wykonywania kopii	Codziennie – automatycznie, w ramach usług dostawcy infrastruktury
Okres przechowywania kopii (retencja)	7 dni – dostępne są kopie z 7 ostatnich dni
Docelowy maksymalny zakres utraty danych (RPO)	Do 24 godzin (wynika z dobowego cyklu kopii)
Docelowy czas odtworzenia (RTO)	.....
Test odtworzenia kopii (częstotliwość, środowisko)	.....

Pozycje oznaczone kropkami uzupełniają Strony przy Wdrożeniu. Wartości RPO i RTO są celami starannego działania (Załącznik nr 3 pkt 8). Licencjodawca nie gwarantuje odtworzenia danych w

każdych okolicznościach, w szczególności gdy przyczyna utraty danych leży po stronie dostawcy infrastruktury. Wynik testu odtworzenia odnotowuje się w protokole odbioru lub w notatce przekazanej Licencjobiorcy w formie dokumentowej. Licencjobiorcy zaleca się okresowe pobieranie raportów i zestawień istotnych dla jego działalności.

4. Uwierzytelnianie i zarządzanie sesjami

- Hasła nigdy nie są przechowywane w postaci jawnej – zapisywane są wyłącznie jako **kryptograficzne skróty z solą** (algorytm odporny na ataki słownikowe).
- Sesje oparte o podpisane cyfrowo tokeny o ograniczonym czasie życia, **automatycznie odświeżane** przy każdym żądaniu.
- Ciasteczka sesyjne z atrybutami ograniczającymi dostęp z poziomu skryptów i innych witryn.
- Potwierdzanie adresu e-mail przy rejestracji jednorazowym kodem oraz bezpieczny, jednorazowy link resetu hasła.
- Powiadomienia e-mail o zmianie hasła lub adresu e-mail – klient natychmiast dowiaduje się o nieautoryzowanych zmianach.
- Konta personelu tworzone są **wewnątrz panelu** – brak możliwości samodzielnej rejestracji do panelu; konta personelu tworzą użytkownicy z uprawnieniami do zarządzania personelem (Administrator oraz – z wyłączeniem kont Administratora – Szef/Kierownik).
- Ochrona przed atakami typu brute-force po stronie usługi uwierzytelniania (ograniczanie liczby prób).

5. Kontrola dostępu oparta na rolach (RBAC)

Każde żądanie do interfejsu programistycznego panelu przechodzi weryfikację tożsamości oraz roli użytkownika **po stronie serwera**. Ukrycie przycisku w interfejsie nigdy nie jest jedynym zabezpieczeniem – nawet spreparowane żądanie bez odpowiednich uprawnień zostanie odrzucone (kody odpowiedzi 401/403).

- Trzy poziomy uprawnień personelu: **Administrator** (osoba wskazana przez Licencjobiorcę), **Szef/Kierownik** oraz **Pracownik** (role robocze: bar, kuchnia, kierowca), a także konto urządzenia kioskowego i rola klienta.
- Dostęp do konta Administratora udostępnia Licencjodawca w ramach Wdrożenia. Dalej Administrator samodzielnie zarządza personelem i decyduje, komu nadaje konta i role, w tym rolę Szef/Kierownik; Szef/Kierownik może zarządzać kontami personelu z wyłączeniem kont i roli Administratora (zob. Załącznik nr 1, pkt 12).
- Zmiana roli użytkownika powoduje unieważnienie jego aktywnych sesji.
- Technicznie egzekwowana ochrona kont Administratora: rola Szef/Kierownik nie może nadać roli Administratora ani zmienić lub usunąć konta Administratora; nie można usunąć ostatniego Administratora.
- Odrębne konto dla urządzenia kioskowego z dostępem ograniczonym do składania zamówień.
- Operacje wrażliwe (usuwanie zamówień, korekty finansowe) dostępne wyłącznie dla poziomów Administrator i Szef/Kierownik.
- Limity bezpieczeństwa dla operacji ręcznych (np. maksymalna jednorazowa korekta gwiazdek przez personel).

6. Izolacja danych na poziomie rekordów

Warstwa danych wyposażona jest w **polityki bezpieczeństwa na poziomie pojedynczych wierszy**. Oznacza to, że nawet przy bezpośrednim zapytaniu do bazy danych użytkownik otrzyma wyłącznie te rekordy, do których ma uprawnienia – np. klient widzi tylko własne zamówienia, kupony i saldo gwiazdek.

- Polityki dostępu obejmują wszystkie tabele zawierające dane klientów i dane operacyjne.
- Uprawnienia anonimowych użytkowników są maksymalnie ograniczone – usunięte zostały m.in. możliwości bezpośredniego usuwania zamówień.
- Logika uprzywilejowana zamknięta jest w **kilkudziesięciu procedurach serwerowych** z kontrolowanym kontekstem uprawnień.
- Klucze o podwyższonych uprawnieniach istnieją wyłącznie po stronie serwera i nigdy nie trafiają do przeglądarki.
- Przeglądy rekomendacji bezpieczeństwa i wydajności warstwy danych wykonywane w miarę potrzeb, z wdrażaniem poprawek (indeksy, zaostrzanie polityk).

7. Bezpieczeństwo logiki biznesowej

- **Ceny i rabaty liczone po stronie serwera** – klient nie jest w stanie zmodyfikować ceny w przeglądarce.
- Operacje krytyczne (złożenie zamówienia, realizacja kuponu, naliczenie gwiazdek, zamknięcie dnia) wykonywane są **atomowo** – w całości albo wcale.
- **Idempotencja zamówień** – unikalny identyfikator żądania zapobiega podwójnym zamówieniom i podwójnym obciążeniom.
- Rezerwacja kodów jednorazowych na czas transakcji, z automatycznym zwolnieniem w razie błędu.
- Walidacja wszystkich danych wejściowych: normalizacja kodów, numerów telefonów, limity długości, kontrola typów.
- Reguły procesu: np. zamówienie nie może zostać wydane bez opłaconego paragonu; zamknięty dzień jest zablokowany przed modyfikacją.

8. Ochrona aplikacji internetowej

Zagrożenie	Zabezpieczenie
Podsłuch / Man-in-the-Middle	Wymuszony HTTPS, certyfikaty SSL/TLS
Wstrzykiwanie SQL	Wyłącznie zapytania parametryzowane i procedury serwerowe
Cross-Site Scripting (XSS)	Automatyczne kodowanie treści przez warstwę prezentacji, brak wstrzykiwania surowego HTML z danych użytkownika
MIME sniffing	Nagłówek X-Content-Type-Options: nosniff
Wyciek adresów URL	Restrykcyjna polityka Referrer-Policy
Open redirect / phishing	Walidacja adresów przekierowań – dozwolone wyłącznie w obrębie własnej domeny
Fingerprinting technologii	Wyłączone nagłówki ujawniające użyte technologie
Eskalacja uprawnień	Autoryzacja ról po stronie serwera, polityki na poziomie rekordów
DDoS	Mechanizmy ochrony sieci brzegowej zapewniane przez dostawcę infrastruktury
Podwójne żądania	Idempotencja operacji

9. Bezpieczeństwo komunikacji w czasie rzeczywistym

Synchronizacja panelu, kuchni i kiosku odbywa się przez **prywatne, autoryzowane kanały**. Tylko zalogowani użytkownicy z odpowiednią rolą mogą subskrybować kanały operacyjne. Zdarzenia są emitowane przez wyzwalacze po stronie warstwy danych, a publiczne strumienie zmian tabel zostały całkowicie wyłączone – eliminując ryzyko podglądania danych przez osoby trzecie.

10. Ochrona programu lojalnościowego

- Postęp poziomu liczony wyłącznie z gwiazdek zdobytych za zakupy.
- Kody promocyjne z limitami użyć, budżetem i datą ważności, weryfikowane po stronie serwera.
- Jednorazowość kuponów i nagród, terminy ważności.
- Ręczne korekty gwiazdek przez personel objęte limitem jednorazowej zmiany.
- Limity koła fortuny i kosztu dodatkowych obrotów egzekwowane po stronie serwera.

11. Integralność danych finansowych i fiskalnych

- Zmiana metody płatności wymaga potwierdzenia i jest trwale rejestrowana (kto, kiedy, z czego na co).
- Blokada modyfikacji zamówień w zamkniętym dniu operacyjnym.
- Kolejka i mechanizm odzyskiwania paragonów fiskalnych po awarii.
- Ewidencja wpłat/wypłat z szuflady oraz raporty kasowe z wykrywaniem rozbieżności.
- Usuwanie zamówień ograniczone do poziomów Administrator i Szef/Kierownik i realizowane kontrolowaną procedurą.

12. Ochrona danych osobowych – RODO

- Przetwarzanie zgodne z Rozporządzeniem (UE) 2016/679 (RODO).
- Polityka prywatności, klauzula informacyjna i regulaminy dostępne w serwisie i kiosku.
- Minimalizacja danych – zbierane są wyłącznie dane niezbędne do realizacji zamówień i programu lojalnościowego.
- Realizacja praw osób, których dane dotyczą: dostęp, sprostowanie, usunięcie, ograniczenie, przenoszenie.
- Baza danych Systemu znajduje się na terenie Unii Europejskiej. Zasady korzystania z dalszych podmiotów przetwarzających określa Załącznik nr 4; w razie przekazywania danych poza EOG stosowane będą wymagane prawem zabezpieczenia transferu.
- Zasady powierzenia przetwarzania danych osobowych określa Załącznik nr 4 do Umowy.

13. Infrastruktura i ciągłość działania

- Infrastruktura dostarczana przez renomowanych dostawców usług chmurowych; informacje o ich certyfikacjach i audytach są dostępne w dokumentacji tych dostawców.
- Architektura bezserwerowa z automatycznym skalowaniem – wysoka odporność na skoki ruchu (np. w trakcie kampanii).
- Wdrożenia projektowane tak, aby nie przerywać pracy restauracji, z możliwością szybkiego powrotu do poprzedniej wersji.
- Rejestrowanie zdarzeń i błędów aplikacji na potrzeby diagnostyki.
- Odseparowane środowiska: produkcyjne i podglądowe/testowe.

14. Zarządzanie incydentami

1. Wykrycie i klasyfikacja zdarzenia (zgłoszenie, analiza zdarzeń).
2. Ograniczenie skutków (np. unieważnienie sesji, rotacja kluczy, blokada konta).
3. Analiza przyczyny i usuni��cie podatności.
4. Powiadomienie Licencjobiorcy bez zbędnej zwłoki po stwierdzeniu naruszenia ochrony danych osobowych (art. 33 ust. 2 RODO), na zasadach z Załącznika nr 4.
5. Pomoc Licencjobiorcy, w niezbędnym zakresie, w wykonaniu jego obowiązków notyfikacyjnych wobec organu nadzorczego (72 h).
6. Wnioski z incydentu i działania zapobiegawcze.

15. Rekomendacje dla Licencjobiorcy

- Stosowanie silnych, unikalnych haseł i nieudostępnianie kont między pracownikami.
- Niezwłoczne usuwanie kont byłych pracowników.
- Zabezpieczenie urządzeń w lokalu (blokada ekranu, aktualizacje systemu).
- Przypisywanie najniższej roli wystarczającej do pracy.

16. Weryfikacja zabezpieczeń

Niniejszy załącznik opisuje mechanizmy bezpieczeństwa zastosowane w Systemie. Nie stanowi raportu z niezależnego audytu ani testu penetracyjnego i nie zawiera takich wyników.

- Weryfikacja wewnętrzna: kontrola poprawności kodu przy budowaniu aplikacji, przegląd polityk dostępu na poziomie rekordów oraz sprawdzenie odrzucania żądań bez wymaganych uprawnień (401/403).
- Licencjobiorca może, na własny koszt, zlecić niezależny test bezpieczeństwa wybranemu podmiotowi, po uprzednim uzgodnieniu z Licencjodawcą w formie dokumentowej zakresu, terminu i metod testu. Testy przeprowadza się w miarę możliwości na środowisku testowym; testy obciążeniowe i działania mogące zakłócić pracę Systemu na środowisku produkcyjnym są niedopuszczalne.
- Wykonawca testu zobowiązuje się do zachowania poufności; raport z testu przekazywany jest Licencjodawcy.
- Podatności potwierdzone w raporcie Licencjodawca usuwa z należytą starannością, w kolejności odpowiadającej ich wadze, w rozsądnym terminie, bez gwarantowanego terminu usunięcia.